

# Relatório de Impacto à Proteção de Dados Pessoais (RIPD) - OrganizaAí

**Data da Elaboração:** 04 de maio de 2026

**Versão:** 1.0

**\*\*Responsável:** Diogo Mendes Baptista e Lucas do Nascimento Lima

## 1. Introdução

Este Relatório de Impacto à Proteção de Dados Pessoais (RIPD) tem como objetivo analisar e documentar os riscos e as medidas de proteção relacionadas ao tratamento de dados pessoais realizado pelo sistema OrganizaAí. O OrganizaAí é uma API RESTful desenvolvida para a gestão inteligente de eventos em grupo, que envolve a coleta e o tratamento de dados pessoais de seus usuários. Este documento visa demonstrar a conformidade com a Lei Geral de Proteção de Dados (LGPD) e identificar ações para mitigar potenciais impactos negativos aos direitos e liberdades dos titulares de dados.

## 2. Descrição do Tratamento de Dados Pessoais

### 2.1. Natureza, Escopo, Contexto e Finalidades do Tratamento

O OrganizaAí é uma plataforma que facilita a organização de eventos sociais. O tratamento de dados pessoais ocorre principalmente no contexto de:

- **Criação e Gestão de Contas:** Usuários se cadastram com nome e e-mail, e suas senhas são criptografadas. Opcionalmente, podem configurar 2FA.
- **Organização de Eventos:** Organizadores criam eventos, sugerem datas, gerenciam participantes e insumos.
- **Participação em Eventos:** Participantes votam em datas, indicam consumo de álcool e interagem com as funcionalidades do evento.
- **Comunicação:** Notificações e informações sobre eventos são enviadas aos participantes.

**Dados Pessoais Tratados:** Nome, e-mail, senha (hash), segredo MFA (opcional), tentativas de login, data de bloqueio, status da conta, permissões (role).

**Finalidades:** Gestão de contas, organização e participação em eventos, segurança do sistema, comunicação e melhoria da experiência do usuário.

### 2.2. Base Legal para o Tratamento

As bases legais para o tratamento de dados pessoais no OrganizaAí incluem:

- **Consentimento:** Para o cadastro e uso da plataforma.
- **Execução de Contrato:** Para a prestação dos serviços de gestão de eventos.
- **Legítimo Interesse:** Para segurança, prevenção de fraudes e melhoria dos serviços.
- **Cumprimento de Obrigação Legal ou Regulatória:** Para atender a requisitos legais aplicáveis.

## 2.3. Categorias de Titulares de Dados

Os titulares de dados são os usuários do sistema OrganizaAí, que podem atuar como organizadores ou participantes de eventos.

## 2.4. Categorias de Dados Pessoais

Conforme detalhado no ROPA, as categorias de dados incluem identificação e contato, autenticação e uso do sistema.

## 2.5. Compartilhamento de Dados

O compartilhamento de dados é limitado a provedores de serviços essenciais (ex: e-mail, hospedagem) e em casos de exigência legal, sempre com garantias de proteção de dados.

## 2.6. Transferência Internacional de Dados

Não há previsão de transferência internacional de dados pessoais no momento. Caso ocorra, será feita em conformidade com a LGPD.

## 2.7. Período de Retenção

Os dados são retidos pelo tempo necessário para as finalidades do tratamento e cumprimento de obrigações legais.

# 3. Avaliação da Necessidade e Proporcionalidade

O tratamento dos dados pessoais é considerado necessário e proporcional para atingir as finalidades propostas pelo OrganizaAí. A coleta de nome e e-mail é fundamental para a identificação do usuário e comunicação. A senha (criptografada) e o 2FA são essenciais para a segurança da conta. Os dados de uso são importantes para o funcionamento do sistema e para aprimorar a experiência do usuário, sempre buscando a anonimização quando possível.

## 4. Análise de Riscos e Medidas de Proteção

| Risco Identificado           | Descrição do Risco                                                                          | Impacto Potencial                                                                      | Medidas de Proteção a Implementar                                                                       |
|------------------------------|---------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Acesso Não Autorizado        | Acesso indevido a contas de usuários ou dados sensíveis por terceiros.                      | Vazamento de dados pessoais, uso indevido de informações, fraudes.                     | Criptografia (BCrypt), Blacklist de IPs, Proteção baseada em papéis (RBAC), Auditoria de acesso.        |
| Vazamento de Dados           | Exposição acidental ou intencional de dados pessoais.                                       | Danos à reputação dos titulares, multas regulatórias, perda de confiança.              | Criptografia em trânsito e em repouso, Desenvolvimento de processos de validação e tratamento de dados. |
| Perda de Dados               | Destruição ou corrupção de dados pessoais devido a falhas de hardware, software ou ataques. | Indisponibilidade do serviço, perda de informações importantes, prejuízos financeiros. | Rotinas de backup regulares, Recuperação de dados, Redundância de sistemas.                             |
| Uso Indevido de Dados        | Utilização dos dados pessoais para finalidades diferentes das informadas.                   | Violação da privacidade, danos aos titulares.                                          | Política de privacidade clara, Consentimento explícito, Acesso restrito, Anonimização de dados.         |
| Ataques de Engenharia Social | Manipulação de usuários para obtenção de informações confidenciais.                         | Acesso não autorizado, vazamento de credenciais.                                       | Campanhas de conscientização, Treinamento de funcionários, Verificação de identidade.                   |

## 5. Medidas para Abordar os Riscos

As medidas de proteção implementadas no OrganizaAí são robustas e visam mitigar os riscos identificados. As principais ações incluem:

- Fortalecimento da Autenticação:** Uso de BCrypt para senhas e 2FA/TOTP para maior segurança no acesso.

- **Gestão de Acesso:** Implementação de RBAC para garantir o princípio do menor privilégio.
- **Segurança no Desenvolvimento:** Adoção de práticas de Security by Design e validação de entradas para prevenir vulnerabilidades.
- **Proteção de Dados:** Criptografia de dados em repouso e em trânsito, além de rotinas de backup e recuperação.
- **Monitoramento Contínuo:** Registro de logs e plano de resposta a incidentes para detecção e tratamento rápido de ameaças.
- **Conscientização:** Treinamento e comunicação sobre segurança da informação para todos os envolvidos.

## 6. Conclusão

O OrganizaAí demonstra um compromisso com a proteção de dados pessoais, incorporando medidas de segurança desde a concepção do projeto. Este RIPD evidencia que os riscos inerentes ao tratamento de dados são identificados e endereçados por meio de controles técnicos e organizacionais adequados. A continuidade da revisão e aprimoramento dessas medidas é fundamental para manter a conformidade e a confiança dos usuários.

## 7. Histórico de Revisões

| Versão | Data       | Descrição da Alteração           | Autor    |
|--------|------------|----------------------------------|----------|
| 1.0    | 04/05/2026 | Elaboração inicial do documento. | Manus AI |